

# Data Privacy & Security Policy

## 1. Overview

This policy establishes the baseline requirements for handling personal data, classifying information assets, and responding to security incidents. It applies to all employees, contractors, and systems that process customer or employee data.

## 2. Data Classification

All data must be classified into one of four tiers: Public, Internal, Confidential, and Restricted. Restricted data includes government identifiers, financial account numbers, authentication credentials, and health information. Restricted data must be encrypted at rest using AES-256 and in transit using TLS 1.2 or higher, and access must be logged and reviewed quarterly.

| Tier         | Examples                       | Encryption at Rest | Access Review |
|--------------|--------------------------------|--------------------|---------------|
| Public       | Marketing pages                | Not required       | N/A           |
| Internal     | Internal wikis                 | Recommended        | Annual        |
| Confidential | Contracts, salaries            | Required           | Semi-annual   |
| Restricted   | SSNs, credentials, health data | Required (AES-256) | Quarterly     |

## 3. Access Control

Access to Confidential and Restricted data follows the principle of least privilege and requires role-based access control (RBAC) with manager approval. Privileged access (administrator or database superuser roles) requires multi-factor authentication and expires automatically after 12 hours unless renewed through a break-glass procedure.

## 4. Data Retention

Personal data collected for a specific purpose must not be retained longer than necessary to fulfill that purpose or to meet legal obligations. Standard retention for customer support transcripts is 24 months; billing records are retained for 7 years to satisfy financial audit requirements. Automated deletion jobs must run monthly and produce an auditable deletion report.

## 5. Incident Response

Any suspected data breach must be reported to the Security team within 1 hour of discovery. The Security team classifies incidents by severity (SEV1-SEV4) and, for any incident involving Restricted data, notifies the Data Protection Officer within 24 hours. Regulatory notification timelines (e.g., 72 hours under GDPR) are tracked separately by the Legal team once an incident is confirmed to involve personal data of EU residents.

## **6. Third-Party Vendors**

Vendors that process Confidential or Restricted data on the company's behalf must sign a Data Processing Agreement and complete an annual security questionnaire. Vendor access to production systems must be time-boxed and reviewed by the vendor's sponsoring team before renewal.